



Chloe Chamberland June 24, 2024

Supply Chain Attack on WordPress.org Plugins Leads to 5 Maliciously Compromised WordPress Plugins

On Monday June 24th, 2024 the Wordfence Threat Intelligence team became aware of a plugin, Social Warfare, that was injected with malicious code on June 22, 2024 based on a forum post by the WordPress.org Plugin Review team. We immediately checked the malicious file and uploaded it to our internal Threat Intelligence platform, which identified four additional plugins that were infected with similar code. We then reached out to the WordPress plugins team to alert them about the four additional plugins but have not yet received a response, though it appears the plugins have been delisted.

As of this writing, we know that the following plugins are infected:

- Social Warfare
  - Patched Version: 4.4.7.2

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

ACCEPT ALL REJECT ALL

Cookie Settings

- Blaze Widget 2.2.5 – 2.5.2
  - Patched Version: None
- Wrapper Link Element 1.0.2 – 1.0.3
  - Patched Version: It appears that someone removed the malicious code, however, the latest version is tagged as 1.0.0 which is lower than the infected versions. This means it may be difficult to update to the latest version, so we recommend removing the plugin until a properly tagged version is released.
- Contact Form 7 Multi-Step Addon 1.0.4 – 1.0.5
  - Patched Version: None
- Simply Show Hooks 1.2.1
  - Patched Version None

At this stage, we know that the injected malware attempts to create a new administrative user account and then sends those details back to the attacker-controlled server. In addition, it appears the threat actor also injected malicious JavaScript into the footer of websites that appears to add SEO spam throughout the website. The injected malicious code is not very sophisticated or heavily obfuscated and contains comments throughout making it easy to follow. The earliest injection appears to date back to June 21st, 2024, and the threat actor was still actively making updates to plugins as recently as 5 hours ago. At this point we do not know exactly how the threat actor was able to infect these plugins.

Currently, the Wordfence Threat Intelligence team is performing a deeper analysis and will provide more information as it becomes available. We are actively working on a set of malware signatures to provide detection for these compromised plugins, however, if you are running a malicious version of one of the plugins, you will be notified by the Wordfence Vulnerability

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Indicators of Compromise

- The following IP Address is the server IP Address where the malicious attacker is sending the data

- 94.156.79.8
- The following are the current known usernames of the administrative user accounts that are being generated
  - wpsvc
  - PluginAuth

If you have any of these plugins installed, you should consider your installation compromised and immediately go into incident response mode. We recommend checking your WordPress administrative user accounts and deleting any that are unauthorized, along with running a complete malware scan with the Wordfence plugin or Wordfence CLI and removing any malicious code.

You can view our full guide to cleaning your WordPress site here, or you can sign up for Wordfence Care or Wordfence Response where we offer complete incident response services for an entire year 24/7/365.

Wordfence

Search the blog SEARCH

Trust Your Site
to the Leader in WordPress Security

Wordfence includes an endpoint firewall, malware scanner, robust login security features, live traffic views, and more. Backed by our Threat Intelligence team, 4 million WordPress sites put their trust in Wordfence.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

PROTECT YOUR SITE

Wordfence

Did you enjoy this post? Share it!

Comments

12 Comments



Irene *
June 24, 2024
9:39 am

I upgraded to the patched version of Social warfare but my Wordfence scan is telling me to remove that plugin completely. Should I be worried?



Chloe Chamberland *
June 24, 2024
9:53 am

Hi Irene, it sounds like you're likely getting a warning because the plugin is currently delisted in the repository. We generally recommend removing any plugins that have been closed or delisted in the repository. However, if you are running Social Warfare on version 4.4.7.3, then you should be able to safely disregard the notice as that

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.



Elizabeth J. McMartin *
June 24, 2024
1:10 pm

Do you think we need to be worried about other plug-in updates? Or was limited to these 5 plug-ins.



Chloe Chamberland *
June 24, 2024
1:30 pm

Hi Elizabeth, at this point it appears to be isolated to just those 5 plugins so I wouldn't worry too much about other plugin updates. However, out of extra caution, I would recommend reviewing the change-sets of any plugin updates prior to updating them on any sites you run to make sure no malicious code is present.



Fabrice Oppitz *
June 25, 2024
2:41 am

Found the maliciously added aministrators accounts replicated in matomo's wp_matomo_user table



Chloe Chamberland *
June 25, 2024
6:19 am

Hi Fabrice, thanks for sharing. It's a good idea to conduct a full site scan and investigation to check one of the infected plugins installed on your site. With the various combinations of plugins and themes out there, there could be remaining artifacts (like you've mentioned) and you can't be sure that no further malware was

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

injected unless you've conducted a thorough investigation and clean.



sophiev *
June 25, 2024
4:41 pm

Hello I had this problem (creation of PluginAUTH admin accounts and troyan horse virus (avast detection) on Sunday 23rd with two websites (Social Warfare installed).
Yesterday June 25th three PluginAUTH admin accounts were created on a third website were none of the involved plugins is installed.
Any idea ?



Chloe Chamberland *
June 26, 2024
5:53 am

Hi Sophie, are the three sites hosted on the same server? If so, it's possible that the infection of the two sites led to the third being infected. If not, would you mind sending us a list of the plugins (and their versions) that you have installed on your site to samples@wordfence.com?



DrGlenn *
June 27, 2024
1:20 am

Obviously, some large % of the sites exploited by these methods... in recent cases, the bad actors add the plugin 'wp code lite' and use the code snippets to inject code throughout. As recently as today, I have found that

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

they add a snippet that hides the wp code lite plugin from the dashboard if the user role is administrator, [illegible] hiding the plugin when the admin looks. Be on the lookout.

Check the wp-content/plugins folder and compare against the listed plugins to check for hidden plugins. Also the mu-plugins and dropins.



Chloe Chamberland *
July 1, 2024
11:45 am

Hi DrGlenn, thanks for sharing! In this case, legitimate WordPress plugins were compromised at the source (WordPress.org), rather than an attacker uploading a malicious plugin after they have already compromised the site. This means that WordPress site owners would be infected when updating their plugin to the latest version available in the repository, rather than an attacker uploading and hiding a malicious WordPress plugin after gaining a foothold through another means.

Kivuhub *
June 29, 2024
4:17 am

We have already updated the plugins and we hope this issue has been solved. We kivuhub we will keep [illegible]

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.



Chloe Chamberland *
July 1, 2024
11:41 am

Hi Kivuhub, thanks for your support! Glad to hear you have updated the plugins - the issue has been resolved in the latest and we do not expect any more plugins to be compromised.

Wordfence

Breaking WordPress Security Research in your inbox as it happens.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

SIGN UP

Our business hours are 8 am–8 pm ET, 6 am–5 pm PT, and 8 am–1 am UTC/GMT. Response customers receive Expert support 365 days a year, with a 1 hour response time.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Terms of Service

Privacy Policy and Notice at Collection

Wordfence

Do Not Sell or Share My Personal Information



Products

Wordfence Free
Wordfence Premium
Wordfence Care
Wordfence Response
Wordfence CLI
Wordfence Intelligence
Wordfence Central

Support

Documentation
Learning Center
Free Support
Premium Support

News

Blog
In The News
Vulnerability Advisories

About

About Wordfence
Affiliate Program
Employment
Contact
Security
CVE Request Form

Stay Updated

Sign up for news and updates from our panel of experienced security professionals.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

SIGN UP

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

© 2012-2026 Defiant Inc. All Rights Reserved

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.